Controls and compliance checklist

Company Name: Botium Toys

Assessment Type: Internal Cybersecurity Audit & Compliance Assessment

Framework: NIST Cybersecurity Framework (NIST CSF)

Controls assessment checklist

Yes	No	Control
	✓	Least Privilege
	✓	Disaster recovery plans
✓		Password policies
	✓	Separation of duties
✓		Firewall
	✓	Intrusion detection system (IDS)
	✓	Backups
✓		Antivirus software
✓		Manual monitoring, maintenance, and intervention for legacy systems
	✓	Encryption
	✓	Password management system
✓		Locks (offices, storefront, warehouse)
✓		Closed-circuit television (CCTV) surveillance
✓		Fire detection/prevention (fire alarm, sprinkler system, etc.)

Compliance checklist

Payment Card Industry Data Security Standard (PCI DSS)

Yes	No	Best practice
	✓	Only authorized users have access to customers' credit card information.
	✓	Credit card information is stored, accepted, processed, and transmitted internally, in a secure environment.
	✓	Implement data encryption procedures to better secure credit card transaction touchpoints and data.
	✓	Adopt secure password management policies.

General Data Protection Regulation (GDPR)

Yes	No	Best practice
	✓	E.U. customers' data is kept private/secured.
✓		There is a plan in place to notify E.U. customers within 72 hours if their data is compromised/there is a breach.
	✓	Ensure data is properly classified and inventoried.
✓		Enforce privacy policies, procedures, and processes to properly document and maintain data.

System and Organizations Controls (SOC type 1, SOC type 2)

Yes	No	Best practice
	✓	User access policies are established.
	✓	Sensitive data (PII/SPII) is confidential/private.
✓		Data integrity ensures the data is consistent, complete, accurate, and has been validated.
✓		Data is available to individuals authorized to access it.

Recommendations:

Based on the internal security audit conducted for Botium Toys, the following controls and compliance best practices are recommended for immediate implementation:

1. Implement Access Control & Least Privilege: Enforce strict user access policies so that only authorized personnel can access sensitive cardholder data and customer PII/SPII.
2. Data Encryption: Deploy robust encryption methods across data processing, transmission, and storage touchpoints to satisfy PCI DSS compliance.
3. Intrusion Detection & Backup Strategy: Install an Intrusion Detection System (IDS) to monitor network threats, and establish an automated backup system alongside a comprehensive Disaster Recovery Plan.
4. Centralized Password Management: Update current password complexity policies and deploy a password manager to streamline reset requests and enhance authentication security.